Week 2- Gap Analysis: M01 Windows 11 Laptop (DESKTOP-TVVAHP9)

Why: The audit shows which Windows settings differ from the CIS recommendation. The gap analysis groups them, links each group to CIS Controls v8, and says how urgent it is. It feeds the Week 3 risk register.

1-Audit facts

Item	Details
Machine	M01 – DESKTOP-TVVAHP9, Windows 11 Enterprise Evaluation, build 26300. Represents the 10 laptops (criticality High).
Tool and date	HardeningKitty 0.9.4, CIS Windows 11 Enterprise 24H2 machine list, 6 November 2026
Result	647 checks: 165 passed, 482 failed (43 Low, 439 Medium, 0 High). Score 3.29 out of 6.
Evidence	W2_Screenshots Figure 5; full results in M01_HardeningKitty_report_20261106.csv

2-How to read it

• **Failed:** HardeningKitty compares each Windows setting with the CIS recommendation. “Failed” means the value found is not the value CIS recommends. It doesn’t always mean the protection is off.

• **Score**: official HardeningKitty method. Each check earns points: passed = 4 points, Low = 2, Medium = 1, High = 0. Score = (points achieved/maximum points) *5+1, on a scale from 1 (worst) to 6 (best). M01: (165*4 + 43*2 + 439*1) = 1.185 points out of 647*4 = 2.588.
1.185/2.588 * 5+1 = 3.29

• **Grouping**: 482 failed checks are too many to read one by one, so they are put into 13 groups by subject (passwords, firewall, updates...). The groups start from HardeniongKitty’s own categories. Each group is linked to one CIS Control v8.

• Priority (same rule as M02): High = a basic protection is missing and client or payroll data is directly exposed; Medium = the basic protection exists but an extra layer is missing; Low = limited impact on the firm’s data.

3-Results by theme

#	Theme	CIS Control v8	Failed	Key evidence	Gap	Priority
W1	Passwords and account lockout	5 Accounts	8	1.1.4 minimum password length: 0 (CIS 14)	Passwords of any length accepted	High
W2	Firewall settings	4 Secure config.	18	9.1.1 firewall on (Domain profile, policy): 0 (CIS 1)	Firewall not enforced by policy; connections not logged	Medium
W3	Malware and exploit protection	10 Malware	56	18.10.43.6.1.1 attack surface reduction rules: 0 (CIS 1)	Extra protection layers not enabled	Medium
W4	Disk encryption (BitLocker)	3 Data protection	40	18.10.10.2.13 extra authentication at startup: 0 (CIS 1)	Disk encryption not enforced by policy	High
W5	Windows Update settings	7 Vulnerability mgmt	12	12 of 14 update checks failed	Updates depend on defaults and users	Medium
W6	Logging and auditing	8 Audit logs	25	18.10.26.2.2 Security log: 4,096 KB (CIS 196,608)	Small log; many events not audited	Medium
W7	User rights	6 Access control	17	2.2.2 network access includes "Everyone"	Rights wider than needed	Medium
W8	Logon, credential and system protections	4 Secure config.	106	2.3.7.1 Ctrl+Alt+Del not required (CIS: required)	Weaker logon protections	Medium
W9	Remote access (Remote Desktop, WinRM)	4 Secure config.	20	18.10.57.3.3.3 drive redirection not blocked	Files can move in remote sessions	Medium
W10	Unneeded services, printing and AutoPlay	4 Secure config.	72	5.14.2 Print Spooler starts automatically (CIS: disabled)	Unneeded services enabled	Medium
W11	Network protocol settings	4 Secure config.	47	18.4.3 SMB v1 server: 1 (CIS 0)	Old network protocols allowed	Medium
W12	Software installation control	2 Software inventory	19	18.10.81.1 users control installs: 1 (CIS 0)	Unauthorised software possible	Medium
W13	Privacy and consumer features	4 Secure config. (closest)	42	18.10.59.3 Cortana allowed	Consumer features allowed	Low

W1-W13: theme numbers of the Windows machine (M01).

CIS Controls v8 full names: • 2 Inventory and Control of Software Assets • 3 Data Protection • 4 Secure Configuration of Enterprise Assets and Software • 5 Account Management • 6 Access Control Management • 7 Continuous Vulnerability Management • 8 Audit Log Management • 10 Malware Defenses.

All 482 failed checks are covered. Every check, with its value found and CIS value, is in the CSV file.

4- Already in place

- Guest account disabled (2.3.1.1). Defender real-time protection not turned off (18.10.43.10.3)
- Inbound connections blocked by default in all firewall profiles (9.1.2, 9.2.2., 9.3.2)
- Screen locks after 15 minutes (2.3.7.4).

5-Main result

Two high gaps on the laptops; weak password rules (W1) and disk encryption not enforced by policy (W4). If a laptop is accessed or lost, client and payroll data are exposed. Both go into the Week 3 risk register, with the M02 High gaps.

Note: HardeningKitty only reads the rules set in Windows. It doesn't check if the firewall is switched on or whether the disk is encrypted right now. So W2 and W4 mean the rule is not set as CIS recommends, not that the firewall is off or that the disk is unencrypted.

6-Sources

- Audit evidence: W2_Screenshots Figure 5; M01_HardeningKitty_report_20261106.csv.
- HardeningKitty: github.com/scipag/HardeningKitty; score method and formula in the official README, section on the HardeningKitty score.
- CIS Controls v8: cisecurity.org/controls/cis-controls-list.
- Method note: no official HardeningKitty-to-CIS mapping exists; linking each theme to a CIS Control is my own analysis. W13 uses the closest control.